UNIVERSIDAD NACIONAL AUTÓNOMA DE NICARAGUA, MANAGUA
UNAN-MANAGUA

2026: "Por una Educación al Servicio del Pueblo, ¡Viva Sandino!"

DEPARTAMENTO DE CIENCIAS TECNOLÓGICAS Y SALUD

INGENIERÍA EN SISTEMAS DE INFORMACIÓN

II SEMESTRE

II Año

Aplicabilidad del Plan de Seguridad ISO/IEC 27001:2022

"Desarrollo de sistema de escritorio para registro, monitoreo y análisis de hábitos saludables estudiantiles, utilizando Apache NetBeans y MySQL"

Grupo 3

AUTORES:

Nerybeth Auxiliadora Bravo López (0009-0004-8994-7504)
Anderson Johan Gonzalez Torrez (0009-0005-7522-8303)
Pablo Francisco Bravo Centeno (0009-0003-4336-041X)
Yeison Alexander Gomez Morales (0009-0009-2135-4207)
Jhon Kenneth Fonseca Pineda (0009-0000-6950-5726)

DOCENTES

Isamar Del Socorro Bonilla Martínez
Yesenia Sobeyda Téllez Gomez
Dionicio Manzanares Lopez

Octubre, 2026

¡Universidad del Pueblo y para el Pueblo!

ÍNDICE

INTRODUCCIÓN **3**
1. CONTROLES APLICABLES AL PROYECTO **4**
1.1 Control 5.2 – Roles y responsabilidades en seguridad de la información **4**
1.2 Control 5.12 – Clasificación de la información **4**
1.3 Control 5.15 – Control de acceso **5**
1.4 Control 5.17 – Información de autenticación **5**
1.5 Control 5.34 – Privacidad y protección de datos de carácter personal (DCP) **5**
1.6 Control 8.5 – Autenticación segura **6**
1.7 Control 8.10 – Eliminación de la información **6**
1.8 Control 8.13 – Copias de seguridad de la información **7**
1.9 Control 8.15 – Registros de eventos **7**
2. CONTROLES QUE NO APLICAN AL PROYECTO **9**
2.1 Control 7.12 – Seguridad del cableado **9**
2.2 Control 8.23 – Filtrado de webs **9**
2.3 Control 8.30 – Externalización del desarrollo **10**

INTRODUCCIÓN

La seguridad de la información es un pilar fundamental en cualquier sistema que almacene y procese datos de las personas. La norma ISO/IEC 27001:2022 establece los requisitos para implementar, mantener y mejorar de forma continua un Sistema de Gestión de la Seguridad de la Información (SGSI), con el fin de proteger la confidencialidad, integridad y disponibilidad de la información.

El presente documento corresponde a la *Aplicabilidad* del Plan de Seguridad ISO/IEC 27001:2022, y se desarrolla sobre el caso de estudio del proyecto "Desarrollo de sistema de escritorio para registro, monitoreo y análisis de hábitos saludables estudiantiles, utilizando Apache NetBeans y MySQL". Este sistema maneja información personal de estudiantes, por lo que es necesario definir qué medidas de seguridad son factibles de implementar y cuáles no se ajustan a las condiciones del proyecto.

Para ello se toma como referencia el Anexo A de la norma, que agrupa los controles de seguridad en cuatro categorías: organizacionales, de personas, de infraestructura y tecnológicos. A partir de este listado se seleccionaron los controles que guardan relación directa con el proyecto, explicando cómo se aplican, y se justifican aquellos controles que no son aplicables a nuestro caso de estudio.

El documento está organizado de la siguiente manera: primero se presentan los controles aplicables al proyecto, cada uno con su descripción, su relación con el sistema y la forma en que se implementa; después se exponen los controles que no se aplican, junto con la justificación de su exclusión. De esta manera se busca demostrar el compromiso del equipo con la protección de la información manejada por el sistema.

1. CONTROLES APLICABLES AL PROYECTO

1.1 Control 5.2 – Roles y responsabilidades en seguridad de la información

Descripción del control
Todos los roles y responsabilidades de seguridad de la información deben definirse y asignarse de acuerdo con las necesidades de la organización.

Relación con el proyecto
El sistema maneja información sensible de estudiantes y requiere que cada persona tenga claras sus responsabilidades. El proyecto define dos roles de usuario, Administrador y Docente, y el equipo de desarrollo tiene roles definidos. Sin responsabilidades asignadas, cualquier usuario podría modificar, eliminar o consultar datos que no le corresponden.

1.2 Control 5.12 – Clasificación de la información

Descripción del control
La información debe clasificarse de acuerdo con las necesidades de seguridad de la información de la organización en función de la confidencialidad, integridad, disponibilidad y los requisitos pertinentes de las partes interesadas

Relación con el proyecto
El sistema almacena información con distintos niveles de sensibilidad: datos personales de menores de edad, registros de sueño y estado de ánimo, y datos generales como la lista de hábitos. No todos requieren la misma protección, por lo que deben clasificarse.

1.3 Control 5.15 – Control de acceso

Descripción del control
Se deben establecer e implementar reglas de control de acceso físico y lógico a la información y otros activos asociados, basadas en los requisitos de negocio y de seguridad de la información.

Relación con el proyecto
Solo el personal autorizado debe acceder al sistema, y cada usuario debe ver únicamente lo que su función requiere. Esto protege los datos de los estudiantes y evita modificaciones no autorizadas.

1.4 Control 5.17 – Información de autenticación

Descripción del control
La asignación y gestión de la información de autenticación debe controlarse mediante un proceso formal de gestión, incluyendo el asesoramiento al personal sobre el tratamiento adecuado de la información.

Relación con el proyecto
Las credenciales (usuario y contraseña) son la puerta de entrada al sistema. Si se gestionan mal, un tercero podría suplantar a un docente o al administrador y alterar o consultar información de los estudiantes.

1.5 Control 5.34 – Privacidad y protección de datos de carácter personal (DCP)

Descripción del control
La organización debe identificar y cumplir con los requisitos relativos a la preservación de la privacidad y la protección de datos de carácter personal (DCP) de acuerdo con las leyes y regulaciones aplicables y los requisitos contractuales.

Relación con el proyecto
El sistema trata datos personales de estudiantes, que son menores de edad, incluyendo información sensible sobre su bienestar. La institución debe protegerlos y usarlos solo para el fin del proyecto.

1.6 Control 8.5 – Autenticación segura

Descripción del control
Las tecnologías y procedimientos de autenticación segura deben implementarse en función de las restricciones de acceso a la información y la política específica sobre control de acceso.

Relación con el proyecto
Complementa el control de acceso con mecanismos técnicos que verifican la identidad del usuario antes de permitirle entrar. Es necesario porque el sistema contiene información confidencial de menores.

1.7 Control 8.10 – Eliminación de la información

Descripción del control
La información almacenada en los sistemas de información, en los dispositivos y cualquier otro medio de almacenamiento debe eliminarse cuando ya no sea necesaria.

Relación con el proyecto
Cuando un estudiante deja de pertenecer a la institución, o cuando ciertos registros ya no son necesarios, su información debe eliminarse de forma controlada para no conservar datos personales innecesariamente

1.8 Control 8.13 – Copias de seguridad de la información

Descripción del control
Las copias de seguridad de la información, del software y de los sistemas deben mantenerse y probarse periódicamente de acuerdo con la política de copias de seguridad específica acordada.

Relación con el proyecto
La pérdida de información es un riesgo identificado en la matriz de riesgos (riesgo #1). Actualmente la institución ya sufre pérdida y duplicidad de registros por llevarlos en papel, y el sistema debe evitar que eso se repita.

1.9 Control 8.15 – Registros de eventos

Descripción del control
Se debe generar, proteger, almacenar y analizar los registros de las actividades, excepciones, fallos y otros eventos relevantes.

Relación con el proyecto
Permite saber quién hizo qué y cuándo dentro del sistema, para detectar acciones no autorizadas y respaldar la responsabilidad de cada usuario.

2. CONTROLES QUE NO APLICAN AL PROYECTO

2.1 Control 7.12 – Seguridad del cableado

Descripción del control
El cableado eléctrico y de telecomunicaciones que transmite datos o que sirve de soporte a los servicios de información debe estar protegido frente a interceptaciones, interferencias o daños.

Justificación de por qué no aplica
No aplica porque el sistema es de escritorio, funciona de forma local

2.2 Control 8.23 – Filtrado de webs

Descripción del control
El acceso a sitios web externos debe gestionarse para reducir la exposición a contenido malicioso.

Justificación de por qué no aplica
No aplica porque el sistema no navega ni consume sitios web externos: es una aplicación de escritorio y los estudiantes no acceden a ella.

2.3 Control 8.30 – Externalización del desarrollo

Descripción del control
La organización debe controlar, monitorizar y revisar las actividades relativas al desarrollo externalizado de sistemas.

Justificación de por qué no aplica
Este control exige supervisar y revisar el desarrollo de sistemas que realiza un tercero. No aplica porque el sistema lo desarrolla íntegramente el equipo del proyecto.